

# Security Scan Report

acme-corp/verademo-dotnet - main

|                           |                        |                       |
|---------------------------|------------------------|-----------------------|
| REPOSITORY                | BRANCH                 | COMMIT                |
| acme-corp/verademo-dotnet | main                   | abc12345              |
| PULL REQUEST              | SCANS INCLUDED         | GENERATED             |
| #7                        | SAST, SCA, IaC/Secrets | 26 Aug 2026 02:44 UTC |

## REVIEW RECOMMENDED

79 of 88 finding(s) meet or exceed the configured severity threshold. They are listed in priority order below.

### Findings by severity

|               |            |              |          |           |
|---------------|------------|--------------|----------|-----------|
| 6<br>CRITICAL | 21<br>HIGH | 52<br>MEDIUM | 9<br>LOW | 0<br>INFO |
|---------------|------------|--------------|----------|-----------|

### Scan coverage

Select a scan name to jump to its findings.

| Scan                                                 | Status       | Threshold | Findings | At/above | Crit | High | Med | Low | Info |
|------------------------------------------------------|--------------|-----------|----------|----------|------|------|-----|-----|------|
| <a href="#">Static Analysis (SAST)</a>               | 69 to review | medium    | 77       | 69       | 4    | 15   | 50  | 8   | 0    |
| <a href="#">Software Composition Analysis (SCA)</a>  | 7 to review  | medium    | 7        | 7        | 1    | 4    | 2   | 0   | 0    |
| <a href="#">Infrastructure as Code &amp; Secrets</a> | 3 to review  | high      | 4        | 3        | 1    | 2    | 0   | 1   | 0    |

### Where to start

The 6 highest-severity findings across all three scans, in priority order. Full detail for every finding follows.

| Severity     | Scan        | Identifier     | Finding                                                                                    | Location                               |
|--------------|-------------|----------------|--------------------------------------------------------------------------------------------|----------------------------------------|
| CRITICAL     | IaC/Secrets | DS031          | Secrets passed via `build-args` or envs or copied secret files                             | Dockerfile:16                          |
| CRITICAL 9.8 | SCA         | CVE-2021-24112 | Remote Code Execution (RCE)                                                                | System.Drawing.Common                  |
| CRITICAL     | SAST        | CWE-78         | Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') | app/controllers/toolscontroller.cs:68  |
| CRITICAL     | SAST        | CWE-78         | Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') | app/controllers/toolscontroller.cs:102 |
| CRITICAL     | SAST        | CWE-79         | Cross-Site Scripting                                                                       | app/wwwroot/js/site.js:12              |
| CRITICAL     | SAST        | CWE-79         | Cross-Site Scripting                                                                       | app/wwwroot/js/site.js:13              |

## Static Analysis (SAST)

**REVIEW** 77 finding(s) - 69 at or above threshold 'medium'

### Static analysis flaws (77)

**CRITICAL** CWE-78

#1

#### Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')

**Location** [app/controllers/toolscontroller.cs:68](#)

**Function** app\_dll.Verademo.Controllers.ToolsController.Ping

**Details** This call to `system_diagnostics_process_dll.System.Diagnostics.Process.Start()` contains a command injection flaw. The argument to the function is constructed using untrusted input. If an attacker is allowed to specify all or part of the command, it may be possible to execute commands on the server with the privileges of the executing process. The level of exposure depends on the effectiveness of input validation routines, if any. `Start()` was called on an object, which contains tainted data. The tainted data originated from earlier calls to `app_dll.VirtualController.vc_mvcentry`, and `app_dll.Verademo.Controllers.ToolsController.Tools`. Validate all untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible. When using blocklists, be sure that the sanitizing routine performs a sufficient number of iterations to remove all instances of disallowed characters. Most APIs that execute system commands also have a "safe" version of the method that takes an array of strings as input rather than a single string, which protects against some forms of command injection.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/78.html>

**CRITICAL** CWE-78

#2

#### Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')

**Location** [app/controllers/toolscontroller.cs:102](#)

**Function** app\_dll.Verademo.Controllers.ToolsController.Fortune

**Details** This call to `system_diagnostics_process_dll.System.Diagnostics.Process.Start()` contains a command injection flaw. The argument to the function is constructed using untrusted input. If an attacker is allowed to specify all or part of the command, it may be possible to execute commands on the server with the privileges of the executing process. The level of exposure depends on the effectiveness of input validation routines, if any. `Start()` was called on an object, which contains tainted data. The tainted data originated from earlier calls to `app_dll.VirtualController.vc_mvcentry`, and `app_dll.Verademo.Controllers.ToolsController.Tools`. Validate all untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible. When using blocklists, be sure that the sanitizing routine performs a sufficient number of iterations to remove all instances of disallowed characters. Most APIs that execute system commands also have a "safe" version of the method that takes an array of strings as input rather than a single string, which protects against some forms of command injection.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/78.html>

**CRITICAL** CWE-79

#3

**Cross-Site Scripting****Location** [app/wwwroot/js/site.js:12](#)**Function** site.render**Scope** js

**Details** This call to `system_diagnostics_process_dll.System.Diagnostics.Process.Start()` contains a command injection flaw. The argument to the function is constructed using untrusted input. If an attacker is allowed to specify all or part of the command, it may be possible to execute commands on the server with the privileges of the executing process. The level of exposure depends on the effectiveness of input validation routines, if any. `Start()` was called on an object, which contains tainted data. The tainted data originated from earlier calls to `app_dll.VirtualController.vc_mvcentry`, and `app_dll.Verademo.Controllers.ToolsController.Tools`. Validate all untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible. When using blocklists, be sure that the sanitizing routine performs a sufficient number of iterations to remove all instances of disallowed characters. Most APIs that execute system commands also have a "safe" version of the method that takes an array of strings as input rather than a single string, which protects against some forms of command injection.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/78.html>**CRITICAL** CWE-79

#4

**Cross-Site Scripting****Location** [app/wwwroot/js/site.js:13](#)**Function** site.render**Scope** js

**Details** This call to `system_diagnostics_process_dll.System.Diagnostics.Process.Start()` contains a command injection flaw. The argument to the function is constructed using untrusted input. If an attacker is allowed to specify all or part of the command, it may be possible to execute commands on the server with the privileges of the executing process. The level of exposure depends on the effectiveness of input validation routines, if any. `Start()` was called on an object, which contains tainted data. The tainted data originated from earlier calls to `app_dll.VirtualController.vc_mvcentry`, and `app_dll.Verademo.Controllers.ToolsController.Tools`. Validate all untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible. When using blocklists, be sure that the sanitizing routine performs a sufficient number of iterations to remove all instances of disallowed characters. Most APIs that execute system commands also have a "safe" version of the method that takes an array of strings as input rather than a single string, which protects against some forms of command injection.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/78.html>**HIGH** CWE-89

#5

**Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')****Location** [app/commands/ignorecommand.cs:33](#)**Function** `app_dll.Verademo.Commands.IgnoreCommand.Execute`

**Details** This database query contains a SQL injection flaw. The call to `system_data_common_dll.System.Data.IDbCommand.ExecuteScalar()` constructs a dynamic SQL query using a variable derived from untrusted input. An attacker could exploit this flaw to execute arbitrary SQL queries against the database. `ExecuteScalar()` was called on an object, which contains tainted data. Avoid dynamically constructing SQL queries. Instead, use parameterized prepared statements to prevent the database from interpreting the contents of bind variables as part of the query. Always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/89.html>

**HIGH** CWE-89

#6

**Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')****Location** [app/commands/ignorecommand.cs:44](#)**Function** `app_dll.Verademo.Commands.IgnoreCommand.Execute`

**Details** This database query contains a SQL injection flaw. The call to `system_data_common_dll.System.Data.IDbCommand.ExecuteNonQuery()` constructs a dynamic SQL query using a variable derived from untrusted input. An attacker could exploit this flaw to execute arbitrary SQL queries against the database. `ExecuteNonQuery()` was called on an object, which contains tainted data. Avoid dynamically constructing SQL queries. Instead, use parameterized prepared statements to prevent the database from interpreting the contents of bind variables as part of the query. Always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/89.html>**HIGH** CWE-89

#7

**Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')****Location** [app/commands/listencommand.cs:54](#)**Function** `app_dll.Verademo.Commands.ListenCommand.Execute`

**Details** This database query contains a SQL injection flaw. The call to `system_data_common_dll.System.Data.IDbCommand.ExecuteNonQuery()` constructs a dynamic SQL query using a variable derived from untrusted input. An attacker could exploit this flaw to execute arbitrary SQL queries against the database. `ExecuteNonQuery()` was called on an object, which contains tainted data. Avoid dynamically constructing SQL queries. Instead, use parameterized prepared statements to prevent the database from interpreting the contents of bind variables as part of the query. Always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/89.html>**HIGH** CWE-89

#8

**Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')****Location** [app/commands/removeaccountcommand.cs:31](#)**Function** `app_dll.Verademo.Commands.RemoveAccountCommand.Execute`

**Details** This database query contains a SQL injection flaw. The call to `system_data_common_dll.System.Data.IDbCommand.ExecuteScalar()` constructs a dynamic SQL query using a variable derived from untrusted input. An attacker could exploit this flaw to execute arbitrary SQL queries against the database. `ExecuteScalar()` was called on an object, which contains tainted data. Avoid dynamically constructing SQL queries. Instead, use parameterized prepared statements to prevent the database from interpreting the contents of bind variables as part of the query. Always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/89.html>**HIGH** CWE-89

#9

**Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')****Location** [app/commands/removeaccountcommand.cs:38](#)**Function** `app_dll.Verademo.Commands.RemoveAccountCommand.Execute`

**Details** This database query contains a SQL injection flaw. The call to `system_data_common_dll.System.Data.IDbCommand.ExecuteNonQuery()` constructs a dynamic SQL query using a variable derived from untrusted input. An attacker could exploit this flaw to execute arbitrary SQL queries against the database. `ExecuteNonQuery()` was called on an object, which contains tainted data. Avoid dynamically constructing SQL queries. Instead, use parameterized prepared statements to prevent the database from interpreting the contents of bind variables as part of the query. Always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/89.html>

**HIGH** CWE-89

#10

**Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')****Location** [app/commands/removeaccountcommand.cs:43](#)**Function** `app_dll.Verademo.Commands.RemoveAccountCommand.Execute`

**Details** This database query contains a SQL injection flaw. The call to `system_data_common_dll.System.Data.IDbCommand.ExecuteNonQuery()` constructs a dynamic SQL query using a variable derived from untrusted input. An attacker could exploit this flaw to execute arbitrary SQL queries against the database. `ExecuteNonQuery()` was called on an object, which contains tainted data. Avoid dynamically constructing SQL queries. Instead, use parameterized prepared statements to prevent the database from interpreting the contents of bind variables as part of the query. Always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/89.html>**HIGH** CWE-89

#11

**Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')****Location** [app/controllers/accountcontroller.cs:365](#)**Function** `app_dll.Verademo.Controllers.AccountController.PopulateProfileViewModel`

**Details** This database query contains a SQL injection flaw. The call to `system_data_common_dll.System.Data.IDbCommand.ExecuteReader()` constructs a dynamic SQL query using a variable derived from untrusted input. An attacker could exploit this flaw to execute arbitrary SQL queries against the database. `ExecuteReader()` was called on an object, which contains tainted data. Avoid dynamically constructing SQL queries. Instead, use parameterized prepared statements to prevent the database from interpreting the contents of bind variables as part of the query. Always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/89.html>**HIGH** CWE-89

#12

**Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')****Location** [app/controllers/accountcontroller.cs:456](#)**Function** `app_dll.Verademo.Controllers.AccountController.RetrieveMyEvents`

**Details** This database query contains a SQL injection flaw. The call to `system_data_common_dll.System.Data.IDbCommand.ExecuteReader()` constructs a dynamic SQL query using a variable derived from untrusted input. An attacker could exploit this flaw to execute arbitrary SQL queries against the database. `ExecuteReader()` was called on an object, which contains tainted data. Avoid dynamically constructing SQL queries. Instead, use parameterized prepared statements to prevent the database from interpreting the contents of bind variables as part of the query. Always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/89.html>**HIGH** CWE-89

#13

**Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')****Location** [app/controllers/authcontrollerbase.cs:24](#)**Function** `app_dll.Verademo.Controllers.AuthControllerBase.LoginUser`

**Details** This database query contains a SQL injection flaw. The call to `entityframework_dll.System.Data.Entity.Database.SqlQuery()` constructs a dynamic SQL query using a variable derived from untrusted input. An attacker could exploit this flaw to execute arbitrary SQL queries against the database. The first argument to `SqlQuery()` contains tainted data from the variable `Concat()`. Avoid dynamically constructing SQL queries. Instead, use parameterized prepared statements to prevent the database from interpreting the contents of bind variables as part of the query. Always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/89.html>

**HIGH** CWE-89

#14

**Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')**Location [app/controllers/blabcontroller.cs:97](#)Function [app\\_dll.Verademo.Controllers.BlabController.PostSearchBlabs](#)

Details This database query contains a SQL injection flaw. The call to `system_data_common_dll.System.Data.IDbCommand.ExecuteReader()` constructs a dynamic SQL query using a variable derived from untrusted input. An attacker could exploit this flaw to execute arbitrary SQL queries against the database. `ExecuteReader()` was called on an object, which contains tainted data. Avoid dynamically constructing SQL queries. Instead, use parameterized prepared statements to prevent the database from interpreting the contents of bind variables as part of the query. Always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible.

Reference <https://downloads.veracode.com/securityscan/cwe/v5/net/89.html>**HIGH** CWE-89

#15

**Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')**Location [app/controllers/blabcontroller.cs:261](#)Function [app\\_dll.Verademo.Controllers.BlabController.PopulateBlabbersViewModel](#)

Details This database query contains a SQL injection flaw. The call to `system_data_common_dll.System.Data.IDbCommand.ExecuteReader()` constructs a dynamic SQL query using a variable derived from untrusted input. An attacker could exploit this flaw to execute arbitrary SQL queries against the database. `ExecuteReader()` was called on an object, which contains tainted data. Avoid dynamically constructing SQL queries. Instead, use parameterized prepared statements to prevent the database from interpreting the contents of bind variables as part of the query. Always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible.

Reference <https://downloads.veracode.com/securityscan/cwe/v5/net/89.html>**HIGH** CWE-79

#16

**Cross-Site Scripting**Location [app/wwwroot/js/site.js:14](#)Function [site.render](#)Scope [js](#)

Details This database query contains a SQL injection flaw. The call to `system_data_common_dll.System.Data.IDbCommand.ExecuteReader()` constructs a dynamic SQL query using a variable derived from untrusted input. An attacker could exploit this flaw to execute arbitrary SQL queries against the database. `ExecuteReader()` was called on an object, which contains tainted data. Avoid dynamically constructing SQL queries. Instead, use parameterized prepared statements to prevent the database from interpreting the contents of bind variables as part of the query. Always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible.

Reference <https://downloads.veracode.com/securityscan/cwe/v5/net/89.html>

**HIGH** CWE-79

#17

## Cross-Site Scripting

**Location** [app/wwwroot/js/site.js:15](#)**Function** site.render**Scope** js

**Details** This database query contains a SQL injection flaw. The call to `system_data_common_dll.System.Data.IDbCommand.ExecuteReader()` constructs a dynamic SQL query using a variable derived from untrusted input. An attacker could exploit this flaw to execute arbitrary SQL queries against the database. `ExecuteReader()` was called on an object, which contains tainted data. Avoid dynamically constructing SQL queries. Instead, use parameterized prepared statements to prevent the database from interpreting the contents of bind variables as part of the query. Always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/89.html>**HIGH** CWE-79

#18

## Cross-Site Scripting

**Location** [app/wwwroot/js/site.js:16](#)**Function** site.render**Scope** js

**Details** This database query contains a SQL injection flaw. The call to `entityframework_dll.System.Data.Entity.Database.SqlQuery()` constructs a dynamic SQL query using a variable derived from untrusted input. An attacker could exploit this flaw to execute arbitrary SQL queries against the database. The first argument to `SqlQuery()` contains tainted data from the variable `Concat()`. Avoid dynamically constructing SQL queries. Instead, use parameterized prepared statements to prevent the database from interpreting the contents of bind variables as part of the query. Always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/89.html>**HIGH** CWE-79

#19

## Cross-Site Scripting

**Location** [app/wwwroot/js/site.js:17](#)**Function** site.render**Scope** js

**Details** This database query contains a SQL injection flaw. The call to `system_data_common_dll.System.Data.IDbCommand.ExecuteReader()` constructs a dynamic SQL query using a variable derived from untrusted input. An attacker could exploit this flaw to execute arbitrary SQL queries against the database. `ExecuteReader()` was called on an object, which contains tainted data. Avoid dynamically constructing SQL queries. Instead, use parameterized prepared statements to prevent the database from interpreting the contents of bind variables as part of the query. Always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/89.html>



**MEDIUM** CWE-80

#20

**Improper Neutralization of Script-Related HTML Tags in a Web Page (Basic XSS)**

|           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|-----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Function  | app_dll.AspNetCoreGeneratedDocument.Views_Tools_Tools._3C_3CExecuteAsync_3Eb__12_0_3Ed.MoveNext                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Scope     | app_dll.AspNetCoreGeneratedDocument.Views_Tools_Tools._3C_3...                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Details   | <p>This call to microsoft_aspnetcore_mvc_viewfeatures_dll.Microsoft.AspNetCore.Mvc.Rendering.IHtmlHelper.Raw() contains a cross-site scripting (XSS) flaw. The application populates the HTTP response with untrusted input, allowing an attacker to embed malicious content, such as Javascript code, which will be executed in the context of the victim's browser. XSS vulnerabilities are commonly exploited to steal or manipulate cookies, modify presentation of content, and compromise confidential information, with new attack vectors being discovered on a regular basis. The first argument to Raw() contains tainted data from the variable Concat(). The tainted data originated from earlier calls to app_dll.Verademo.Controllers.ToolsController.Tools, and app_dll.VirtualController.vc_mvcentry. Use contextual escaping on all untrusted data before using it to construct any portion of an HTTP response. The escaping method should be chosen based on the specific use case of the untrusted data, otherwise it may not protect fully against the attack. For example, if the data is being written to the body of an HTML page, use HTML entity escaping; if the data is being written to an attribute, use attribute e...</p> |
| Reference | <a href="https://downloads.veracode.com/securityscan/cwe/v5/net/80.html">https://downloads.veracode.com/securityscan/cwe/v5/net/80.html</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |

**MEDIUM** CWE-80

#21

**Improper Neutralization of Script-Related HTML Tags in a Web Page (Basic XSS)**

|           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|-----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Function  | app_dll.AspNetCoreGeneratedDocument.Views_Blab_Feed._3CExecuteAsync_3Ed__13.MoveNext                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Scope     | app_dll.AspNetCoreGeneratedDocument.Views_Blab_Feed._3CExec...                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Details   | <p>This call to microsoft_aspnetcore_mvc_razor_dll.Microsoft.AspNetCore.Mvc.Razor.RazorPageBase.Write() contains a cross-site scripting (XSS) flaw. The application populates the HTTP response with untrusted input, allowing an attacker to embed malicious content, such as Javascript code, which will be executed in the context of the victim's browser. XSS vulnerabilities are commonly exploited to steal or manipulate cookies, modify presentation of content, and compromise confidential information, with new attack vectors being discovered on a regular basis. The first argument to Write() contains tainted data from the variable &lt;&gt;4__this.get_Html().Raw(). The tainted data originated from an earlier call to system_data_common_dll.System.Data.Common.DbCommand.ExecuteReader. Use contextual escaping on all untrusted data before using it to construct any portion of an HTTP response. The escaping method should be chosen based on the specific use case of the untrusted data, otherwise it may not protect fully against the attack. For example, if the data is being written to the body of an HTML page, use HTML entity escaping; if the data is being written to an attribute, use attribute escaping; etc....</p> |
| Reference | <a href="https://downloads.veracode.com/securityscan/cwe/v5/net/80.html">https://downloads.veracode.com/securityscan/cwe/v5/net/80.html</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |

**MEDIUM** CWE-80

#22

**Improper Neutralization of Script-Related HTML Tags in a Web Page (Basic XSS)**

|           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|-----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Function  | app_dll.AspNetCoreGeneratedDocument.Views_Blab_Feed._3CExecuteAsync_3Ed__13.MoveNext                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Scope     | app_dll.AspNetCoreGeneratedDocument.Views_Blab_Feed._3CExec...                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Details   | <p>This call to microsoft_aspnetcore_mvc_razor_dll.Microsoft.AspNetCore.Mvc.Razor.RazorPageBase.Write() contains a cross-site scripting (XSS) flaw. The application populates the HTTP response with untrusted input, allowing an attacker to embed malicious content, such as Javascript code, which will be executed in the context of the victim's browser. XSS vulnerabilities are commonly exploited to steal or manipulate cookies, modify presentation of content, and compromise confidential information, with new attack vectors being discovered on a regular basis. The first argument to Write() contains tainted data from the variable &lt;&gt;4__this.get_Html().Raw(). The tainted data originated from an earlier call to system_data_common_dll.System.Data.Common.DbCommand.ExecuteReader. Use contextual escaping on all untrusted data before using it to construct any portion of an HTTP response. The escaping method should be chosen based on the specific use case of the untrusted data, otherwise it may not protect fully against the attack. For example, if the data is being written to the body of an HTML page, use HTML entity escaping; if the data is being written to an attribute, use attribute escaping; etc....</p> |
| Reference | <a href="https://downloads.veracode.com/securityscan/cwe/v5/net/80.html">https://downloads.veracode.com/securityscan/cwe/v5/net/80.html</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |



**MEDIUM** CWE-80

#23

**Improper Neutralization of Script-Related HTML Tags in a Web Page (Basic XSS)**

|           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Function  | app_dll.AspNetCoreGeneratedDocument.Views_Tools_Tools._3C_3CExecuteAsync_3Eb__12_0_3Ed.MoveNext                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Scope     | app_dll.AspNetCoreGeneratedDocument.Views_Tools_Tools._3C_3...                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Details   | This call to microsoft_aspnetcore_mvc_razor_dll.Microsoft.AspNetCore.Mvc.Razor.RazorPageBase.Write() contains a cross-site scripting (XSS) flaw. The application populates the HTTP response with untrusted input, allowing an attacker to embed malicious content, such as Javascript code, which will be executed in the context of the victim's browser. XSS vulnerabilities are commonly exploited to steal or manipulate cookies, modify presentation of content, and compromise confidential information, with new attack vectors being discovered on a regular basis. The first argument to Write() contains tainted data from the variable <>4__this.get_Html().Raw(). The tainted data originated from earlier calls to app_dll.Verademo.Controllers.ToolsController.Tools, and app_dll.VirtualController.vc_mvcentry. Use contextual escaping on all untrusted data before using it to construct any portion of an HTTP response. The escaping method should be chosen based on the specific use case of the untrusted data, otherwise it may not protect fully against the attack. For example, if the data is being written to the body of an HTML page, use HTML entity escaping; if the data is being written to an attribute, us... |
| Reference | <a href="https://downloads.veracode.com/securityscan/cwe/v5/net/80.html">https://downloads.veracode.com/securityscan/cwe/v5/net/80.html</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |

**MEDIUM** CWE-80

#24

**Improper Neutralization of Script-Related HTML Tags in a Web Page (Basic XSS)**

|           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Function  | app_dll.AspNetCoreGeneratedDocument.Views_Blab_Feed._3CExecuteAsync_3Ed__13.MoveNext                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Scope     | app_dll.AspNetCoreGeneratedDocument.Views_Blab_Feed._3CExec...                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Details   | This call to microsoft_aspnetcore_mvc_viewfeatures_dll.Microsoft.AspNetCore.Mvc.Rendering.IHtmlHelper.Raw() contains a cross-site scripting (XSS) flaw. The application populates the HTTP response with untrusted input, allowing an attacker to embed malicious content, such as Javascript code, which will be executed in the context of the victim's browser. XSS vulnerabilities are commonly exploited to steal or manipulate cookies, modify presentation of content, and compromise confidential information, with new attack vectors being discovered on a regular basis. The first argument to Raw() contains tainted data from the variable <post>5__6.get_Content(). The tainted data originated from an earlier call to system_data_common_dll.System.Data.Common.DbCommand.ExecuteReader. Use contextual escaping on all untrusted data before using it to construct any portion of an HTTP response. The escaping method should be chosen based on the specific use case of the untrusted data, otherwise it may not protect fully against the attack. For example, if the data is being written to the body of an HTML page, use HTML entity escaping; if the data is being written to an attribute, use attribute escaping; e... |
| Reference | <a href="https://downloads.veracode.com/securityscan/cwe/v5/net/80.html">https://downloads.veracode.com/securityscan/cwe/v5/net/80.html</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |

**MEDIUM** CWE-80

#25

**Improper Neutralization of Script-Related HTML Tags in a Web Page (Basic XSS)**

|           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Function  | app_dll.AspNetCoreGeneratedDocument.Views_Blab_Blab._3CExecuteAsync_3Ed__13.MoveNext                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Scope     | app_dll.AspNetCoreGeneratedDocument.Views_Blab_Blab._3CExec...                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Details   | This call to microsoft_aspnetcore_mvc_razor_dll.Microsoft.AspNetCore.Mvc.Razor.RazorPageBase.Write() contains a cross-site scripting (XSS) flaw. The application populates the HTTP response with untrusted input, allowing an attacker to embed malicious content, such as Javascript code, which will be executed in the context of the victim's browser. XSS vulnerabilities are commonly exploited to steal or manipulate cookies, modify presentation of content, and compromise confidential information, with new attack vectors being discovered on a regular basis. The first argument to Write() contains tainted data from the variable <>4__this.get_Html().Raw(). The tainted data originated from an earlier call to system_data_common_dll.System.Data.Common.DbCommand.ExecuteReader. Use contextual escaping on all untrusted data before using it to construct any portion of an HTTP response. The escaping method should be chosen based on the specific use case of the untrusted data, otherwise it may not protect fully against the attack. For example, if the data is being written to the body of an HTML page, use HTML entity escaping; if the data is being written to an attribute, use attribute escaping; etc.... |
| Reference | <a href="https://downloads.veracode.com/securityscan/cwe/v5/net/80.html">https://downloads.veracode.com/securityscan/cwe/v5/net/80.html</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |

**MEDIUM** CWE-80

#26

### Improper Neutralization of Script-Related HTML Tags in a Web Page (Basic XSS)

|           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|-----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Function  | app_dll.AspNetCoreGeneratedDocument.Views_Blab_Feed._3CExecuteAsync_3Ed__13.MoveNext                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Scope     | app_dll.AspNetCoreGeneratedDocument.Views_Blab_Feed._3CExec...                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Details   | <p>This call to <code>microsoft_aspnetcore_mvc_viewfeatures_dll.Microsoft.AspNetCore.Mvc.Rendering.IHtmlHelper.Raw()</code> contains a cross-site scripting (XSS) flaw. The application populates the HTTP response with untrusted input, allowing an attacker to embed malicious content, such as Javascript code, which will be executed in the context of the victim's browser. XSS vulnerabilities are commonly exploited to steal or manipulate cookies, modify presentation of content, and compromise confidential information, with new attack vectors being discovered on a regular basis. The first argument to <code>Raw()</code> contains tainted data from the variable <code>&lt;post&gt;5__4.get_Content()</code>. The tainted data originated from an earlier call to <code>system_data_common_dll.System.Data.Common.DbCommand.ExecuteReader</code>. Use contextual escaping on all untrusted data before using it to construct any portion of an HTTP response. The escaping method should be chosen based on the specific use case of the untrusted data, otherwise it may not protect fully against the attack. For example, if the data is being written to the body of an HTML page, use HTML entity escaping; if the data is being written to an attribute, use attribute escaping; e...</p> |
| Reference | <a href="https://downloads.veracode.com/securityscan/cwe/v5/net/80.html">https://downloads.veracode.com/securityscan/cwe/v5/net/80.html</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |

**MEDIUM** CWE-80

#27

### Improper Neutralization of Script-Related HTML Tags in a Web Page (Basic XSS)

|           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|-----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Function  | app_dll.AspNetCoreGeneratedDocument.Views_Blab_Blab._3CExecuteAsync_3Ed__13.MoveNext                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Scope     | app_dll.AspNetCoreGeneratedDocument.Views_Blab_Blab._3CExec...                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Details   | <p>This call to <code>microsoft_aspnetcore_mvc_viewfeatures_dll.Microsoft.AspNetCore.Mvc.Rendering.IHtmlHelper.Raw()</code> contains a cross-site scripting (XSS) flaw. The application populates the HTTP response with untrusted input, allowing an attacker to embed malicious content, such as Javascript code, which will be executed in the context of the victim's browser. XSS vulnerabilities are commonly exploited to steal or manipulate cookies, modify presentation of content, and compromise confidential information, with new attack vectors being discovered on a regular basis. The first argument to <code>Raw()</code> contains tainted data from the variable <code>&lt;comment&gt;5__3.get_Content()</code>. The tainted data originated from an earlier call to <code>system_data_common_dll.System.Data.Common.DbCommand.ExecuteReader</code>. Use contextual escaping on all untrusted data before using it to construct any portion of an HTTP response. The escaping method should be chosen based on the specific use case of the untrusted data, otherwise it may not protect fully against the attack. For example, if the data is being written to the body of an HTML page, use HTML entity escaping; if the data is being written to an attribute, use attribute escaping...</p> |
| Reference | <a href="https://downloads.veracode.com/securityscan/cwe/v5/net/80.html">https://downloads.veracode.com/securityscan/cwe/v5/net/80.html</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |

**MEDIUM** CWE-117

#28

### Improper Output Neutralization for Logs

|           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|-----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Location  | <a href="#">app/commands/ignorecommand.cs:32</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Function  | app_dll.Verademo.Commands.IgnoreCommand.Execute                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Details   | <p>This call to <code>log4net_dll.log4net.ILog.Info()</code> could result in a log forging attack. Writing untrusted data into a log file allows an attacker to forge log entries or inject malicious content into log files. Corrupted log files can be used to cover an attacker's tracks or as a delivery mechanism for an attack on a log viewing or processing utility. For example, if a web administrator uses a browser-based utility to review logs, a cross-site scripting attack might be possible. The first argument to <code>Info()</code> contains tainted data. The tainted data originated from earlier calls to <code>app_dll.Verademo.Controllers.BlabController.PostBlabbers</code>, and <code>app_dll.VirtualController.vc_mvcentry</code>. Avoid directly embedding user input in log files when possible. Sanitize untrusted data used to construct log entries by using a safe logging mechanism such as the OWASP ESAPI Logger, which will automatically remove unexpected carriage returns and line feeds and can be configured to use HTML entity encoding for non-alphanumeric data. Alternatively, some of the XSS escaping functions from the OWASP Java Encoder project will also sanitize CRLF sequences. Only create a custom blacklist when absolutely necessary. Al...</p> |
| Reference | <a href="https://downloads.veracode.com/securityscan/cwe/v5/net/117.html">https://downloads.veracode.com/securityscan/cwe/v5/net/117.html</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |

**MEDIUM** CWE-117

#29

**Improper Output Neutralization for Logs****Location** [app/commands/ignorecommand.cs:43](#)**Function** `app_dll.Verademo.Commands.IgnoreCommand.Execute`

**Details** This call to `log4net_dll.log4net.ILog.Info()` could result in a log forging attack. Writing untrusted data into a log file allows an attacker to forge log entries or inject malicious content into log files. Corrupted log files can be used to cover an attacker's tracks or as a delivery mechanism for an attack on a log viewing or processing utility. For example, if a web administrator uses a browser-based utility to review logs, a cross-site scripting attack might be possible. The first argument to `Info()` contains tainted data. The tainted data originated from earlier calls to `app_dll.Verademo.Controllers.BlabController.PostBlabbers`, `app_dll.VirtualController.vc_mvcentry`, and `system_data_common_dll.System.Data.Common.DbCommand.ExecuteScalar`. Avoid directly embedding user input in log files when possible. Sanitize untrusted data used to construct log entries by using a safe logging mechanism such as the OWASP ESAPI Logger, which will automatically remove unexpected carriage returns and line feeds and can be configured to use HTML entity encoding for non-alphanumeric data. Alternatively, some of the XSS escaping functions from the OWASP Java Encoder project will also sanitize CRLF sequ...

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/117.html>**MEDIUM** CWE-117

#30

**Improper Output Neutralization for Logs****Location** [app/commands/listencommand.cs:52](#)**Function** `app_dll.Verademo.Commands.ListenCommand.Execute`

**Details** This call to `log4net_dll.log4net.ILog.Info()` could result in a log forging attack. Writing untrusted data into a log file allows an attacker to forge log entries or inject malicious content into log files. Corrupted log files can be used to cover an attacker's tracks or as a delivery mechanism for an attack on a log viewing or processing utility. For example, if a web administrator uses a browser-based utility to review logs, a cross-site scripting attack might be possible. The first argument to `Info()` contains tainted data. The tainted data originated from earlier calls to `app_dll.VirtualController.vc_mvcentry`, `app_dll.Verademo.Controllers.BlabController.PostBlabbers`, and `system_data_common_dll.System.Data.Common.DbCommand.ExecuteReader`. Avoid directly embedding user input in log files when possible. Sanitize untrusted data used to construct log entries by using a safe logging mechanism such as the OWASP ESAPI Logger, which will automatically remove unexpected carriage returns and line feeds and can be configured to use HTML entity encoding for non-alphanumeric data. Alternatively, some of the XSS escaping functions from the OWASP Java Encoder project will also sanitize CRLF sequ...

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/117.html>**MEDIUM** CWE-117

#31

**Improper Output Neutralization for Logs****Location** [app/commands/removeaccountcommand.cs:30](#)**Function** `app_dll.Verademo.Commands.RemoveAccountCommand.Execute`

**Details** This call to `log4net_dll.log4net.ILog.Info()` could result in a log forging attack. Writing untrusted data into a log file allows an attacker to forge log entries or inject malicious content into log files. Corrupted log files can be used to cover an attacker's tracks or as a delivery mechanism for an attack on a log viewing or processing utility. For example, if a web administrator uses a browser-based utility to review logs, a cross-site scripting attack might be possible. The first argument to `Info()` contains tainted data. The tainted data originated from earlier calls to `app_dll.Verademo.Controllers.BlabController.PostBlabbers`, and `app_dll.VirtualController.vc_mvcentry`. Avoid directly embedding user input in log files when possible. Sanitize untrusted data used to construct log entries by using a safe logging mechanism such as the OWASP ESAPI Logger, which will automatically remove unexpected carriage returns and line feeds and can be configured to use HTML entity encoding for non-alphanumeric data. Alternatively, some of the XSS escaping functions from the OWASP Java Encoder project will also sanitize CRLF sequences. Only create a custom blocklist when absolutely necessary. Al...

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/117.html>

**MEDIUM** CWE-117

#32

**Improper Output Neutralization for Logs****Location** [app/commands/removeaccountcommand.cs:36](#)**Function** app\_dll.Verademo.Commands.RemoveAccountCommand.Execute

**Details** This call to `log4net_dll.log4net.ILog.Info()` could result in a log forging attack. Writing untrusted data into a log file allows an attacker to forge log entries or inject malicious content into log files. Corrupted log files can be used to cover an attacker's tracks or as a delivery mechanism for an attack on a log viewing or processing utility. For example, if a web administrator uses a browser-based utility to review logs, a cross-site scripting attack might be possible. The first argument to `Info()` contains tainted data. The tainted data originated from earlier calls to `app_dll.Verademo.Controllers.BlabController.PostBlabbers`, `app_dll.VirtualController.vc_mvcentry`, and `system_data_common_dll.System.Data.Common.DbCommand.ExecuteScalar`. Avoid directly embedding user input in log files when possible. Sanitize untrusted data used to construct log entries by using a safe logging mechanism such as the OWASP ESAPI Logger, which will automatically remove unexpected carriage returns and line feeds and can be configured to use HTML entity encoding for non-alphanumeric data. Alternatively, some of the XSS escaping functions from the OWASP Java Encoder project will also sanitize CRLF sequ...

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/117.html>**MEDIUM** CWE-117

#33

**Improper Output Neutralization for Logs****Location** [app/commands/removeaccountcommand.cs:41](#)**Function** app\_dll.Verademo.Commands.RemoveAccountCommand.Execute

**Details** This call to `log4net_dll.log4net.ILog.Info()` could result in a log forging attack. Writing untrusted data into a log file allows an attacker to forge log entries or inject malicious content into log files. Corrupted log files can be used to cover an attacker's tracks or as a delivery mechanism for an attack on a log viewing or processing utility. For example, if a web administrator uses a browser-based utility to review logs, a cross-site scripting attack might be possible. The first argument to `Info()` contains tainted data. The tainted data originated from earlier calls to `app_dll.Verademo.Controllers.BlabController.PostBlabbers`, and `app_dll.VirtualController.vc_mvcentry`. Avoid directly embedding user input in log files when possible. Sanitize untrusted data used to construct log entries by using a safe logging mechanism such as the OWASP ESAPI Logger, which will automatically remove unexpected carriage returns and line feeds and can be configured to use HTML entity encoding for non-alphanumeric data. Alternatively, some of the XSS escaping functions from the OWASP Java Encoder project will also sanitize CRLF sequences. Only create a custom blacklist when absolutely necessary. Al...

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/117.html>**MEDIUM** CWE-502

#34

**Deserialization of Untrusted Data****Location** [app/controllers/accountcontroller.cs:59](#)**Function** app\_dll.Verademo.Controllers.AccountController.GetLogin

**Details** The serialized-JSON data stream used in the call to `newtonsoft_json_dll.Newtonsoft.Json.JsonConvert.DeserializeObject()` appears to have been constructed with external (possibly untrusted) data. Because `TypeNameHandling` (in `JsonSerializerSettings`) is set to anything other than `None`, `Newtonsoft.Json` is configured to include object type information in the output and processes it from the given input. Attacker manipulation of this stream has the ability to cause the creation of objects of arbitrary serializable types. Paired with a weakness in another class's constructor, this could result in a denial of service, code execution, or data corruption vulnerability. Always use `Newtonsoft.Json` with default `JsonSerializerSettings` or with `TypeNameHandling` explicitly set to `None`.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/502.html>

**MEDIUM** CWE-73

#35

**External Control of File Name or Path****Location** [app/controllers/accountcontroller.cs:229](#)**Function** app\_dll.Verademo.Controllers.AccountController.PostProfile

**Details** This call to `system_runtime_dll.System.IO.File.Delete()` contains a path manipulation flaw. The argument to the function is a filename constructed using untrusted input. If an attacker is allowed to specify all or part of the filename, it may be possible to gain unauthorized access to files on the server, including those outside the webroot, that would be normally be inaccessible to end users. The level of exposure depends on the effectiveness of input validation routines, if any. The first argument to `Delete()` contains tainted data. The tainted data originated from earlier calls to `app_dll.VirtualController.vc_mvcentry`, and `app_dll.Verademo.Controllers.AccountController.PostProfile`. Validate all untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible. When using blocklists, be sure that the sanitizing routine performs a sufficient number of iterations to remove all instances of disallowed characters.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/73.html>**MEDIUM** CWE-73

#36

**External Control of File Name or Path****Location** [app/controllers/accountcontroller.cs:332](#)**Function** app\_dll.Verademo.Controllers.AccountController.UpdateUsername

**Details** This call to `system_runtime_dll.System.IO.File.Move()` contains a path manipulation flaw. The argument to the function is a filename constructed using untrusted input. If an attacker is allowed to specify all or part of the filename, it may be possible to gain unauthorized access to files on the server, including those outside the webroot, that would be normally be inaccessible to end users. The level of exposure depends on the effectiveness of input validation routines, if any. The first argument to `Move()` contains tainted data. The tainted data originated from earlier calls to `app_dll.Verademo.Controllers.AccountController.PostProfile`, `app_dll.VirtualController.vc_mvcentry`, `microsoft_aspnetcore_http_abstractions_dll.Microsoft.AspNetCore.Http.HttpContext.get_Session`, and `app_dll.Verademo.Controllers.AccountController.PostRegister`. Validate all untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible. When using blocklists, be sure that the sanitizing routine performs a sufficient number of iterations to remove all instances of disallowed characters.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/73.html>**MEDIUM** CWE-73

#37

**External Control of File Name or Path****Location** [app/controllers/accountcontroller.cs:332](#)**Function** app\_dll.Verademo.Controllers.AccountController.UpdateUsername

**Details** This call to `system_runtime_dll.System.IO.File.Move()` contains a path manipulation flaw. The argument to the function is a filename constructed using untrusted input. If an attacker is allowed to specify all or part of the filename, it may be possible to gain unauthorized access to files on the server, including those outside the webroot, that would be normally be inaccessible to end users. The level of exposure depends on the effectiveness of input validation routines, if any. The second argument to `Move()` contains tainted data. The tainted data originated from earlier calls to `app_dll.Verademo.Controllers.AccountController.PostProfile`, and `app_dll.VirtualController.vc_mvcentry`. Validate all untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible. When using blocklists, be sure that the sanitizing routine performs a sufficient number of iterations to remove all instances of disallowed characters.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/73.html>

**MEDIUM** CWE-73

#38

**External Control of File Name or Path****Location** [app/controllers/accountcontroller.cs:393](#)**Function** `app_dll.Verademo.Controllers.AccountController.DownloadProfileImage`

**Details** This call to `microsoft_aspnetcore_mvc_core_dll.Microsoft.AspNetCore.Mvc.ControllerBase.PhysicalFile()` contains a path manipulation flaw. The argument to the function is a filename constructed using untrusted input. If an attacker is allowed to specify all or part of the filename, it may be possible to gain unauthorized access to files on the server, including those outside the webroot, that would be normally be inaccessible to end users. The level of exposure depends on the effectiveness of input validation routines, if any. The first argument to `PhysicalFile()` contains tainted data. The tainted data originated from earlier calls to `app_dll.VirtualController.vc_mvcentry`, and `app_dll.Verademo.Controllers.AccountController.DownloadProfileImage`. Validate all untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible. When using blocklists, be sure that the sanitizing routine performs a sufficient number of iterations to remove all instances of disallowed characters.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/73.html>**MEDIUM** CWE-73

#39

**External Control of File Name or Path****Location** [app/controllers/accountcontroller.cs:537](#)**Function** `app_dll.Verademo.Controllers.AccountController.PostRegisterFinish`

**Details** This call to `system_runtime_dll.System.IO.File.Copy()` contains a path manipulation flaw. The argument to the function is a filename constructed using untrusted input. If an attacker is allowed to specify all or part of the filename, it may be possible to gain unauthorized access to files on the server, including those outside the webroot, that would be normally be inaccessible to end users. The level of exposure depends on the effectiveness of input validation routines, if any. The second argument to `Copy()` contains tainted data from the variable `Concat()`. The tainted data originated from an earlier call to `app_dll.VirtualController.vc_mvcentry`. Validate all untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible. When using blocklists, be sure that the sanitizing routine performs a sufficient number of iterations to remove all instances of disallowed characters.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/73.html>**MEDIUM** CWE-80

#40

**Improper Neutralization of Script-Related HTML Tags in a Web Page (Basic XSS)****Location** [app/controllers/accountcontroller.cs:274](#)**Function** `app_dll.Verademo.Controllers.AccountController.GetPasswordHint`

**Details** This call to `microsoft_aspnetcore_mvc_core_dll.Microsoft.AspNetCore.Mvc.ControllerBase.Content()` contains a cross-site scripting (XSS) flaw. The application populates the HTTP response with untrusted input, allowing an attacker to embed malicious content, such as Javascript code, which will be executed in the context of the victim's browser. XSS vulnerabilities are commonly exploited to steal or manipulate cookies, modify presentation of content, and compromise confidential information, with new attack vectors being discovered on a regular basis. The first argument to `Content()` contains tainted data from the variable `Concat()`. The tainted data originated from earlier calls to `app_dll.Verademo.Controllers.AccountController.GetPasswordHint`, and `app_dll.VirtualController.vc_mvcentry`. Use contextual escaping on all untrusted data before using it to construct any portion of an HTTP response. The escaping method should be chosen based on the specific use case of the untrusted data, otherwise it may not protect fully against the attack. For example, if the data is being written to the body of an HTML page, use HTML entity escaping; if the data is being written to an attribute, use `attrib...`

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/80.html>



**MEDIUM** CWE-80

#41

### Improper Neutralization of Script-Related HTML Tags in a Web Page (Basic XSS)

**Location** [app/controllers/accountcontroller.cs:279](#)**Function** app\_dll.Verademo.Controllers.AccountController.GetPasswordHint

**Details** This call to `microsoft_aspnetcore_mvc_core_dll.Microsoft.AspNetCore.Mvc.ControllerBase.Content()` contains a cross-site scripting (XSS) flaw. The application populates the HTTP response with untrusted input, allowing an attacker to embed malicious content, such as Javascript code, which will be executed in the context of the victim's browser. XSS vulnerabilities are commonly exploited to steal or manipulate cookies, modify presentation of content, and compromise confidential information, with new attack vectors being discovered on a regular basis. The first argument to `Content()` contains tainted data from the variable `Concat()`. The tainted data originated from earlier calls to `app_dll.VirtualController.vc_mvcentry`, and `app_dll.Verademo.Controllers.AccountController.GetPasswordHint`. Use contextual escaping on all untrusted data before using it to construct any portion of an HTTP response. The escaping method should be chosen based on the specific use case of the untrusted data, otherwise it may not protect fully against the attack. For example, if the data is being written to the body of an HTML page, use HTML entity escaping; if the data is being written to an attribute, use `attrib...`

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/80.html>**MEDIUM** CWE-80

#42

### Improper Neutralization of Script-Related HTML Tags in a Web Page (Basic XSS)

**Location** [app/controllers/accountcontroller.cs:282](#)**Function** app\_dll.Verademo.Controllers.AccountController.GetPasswordHint

**Details** This call to `microsoft_aspnetcore_mvc_core_dll.Microsoft.AspNetCore.Mvc.ControllerBase.Content()` contains a cross-site scripting (XSS) flaw. The application populates the HTTP response with untrusted input, allowing an attacker to embed malicious content, such as Javascript code, which will be executed in the context of the victim's browser. XSS vulnerabilities are commonly exploited to steal or manipulate cookies, modify presentation of content, and compromise confidential information, with new attack vectors being discovered on a regular basis. The first argument to `Content()` contains tainted data from the variable `Format()`. The tainted data originated from earlier calls to `app_dll.Verademo.Controllers.AccountController.GetPasswordHint`, and `app_dll.VirtualController.vc_mvcentry`. Use contextual escaping on all untrusted data before using it to construct any portion of an HTTP response. The escaping method should be chosen based on the specific use case of the untrusted data, otherwise it may not protect fully against the attack. For example, if the data is being written to the body of an HTML page, use HTML entity escaping; if the data is being written to an attribute, use `attrib...`

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/80.html>**MEDIUM** CWE-117

#43

### Improper Output Neutralization for Logs

**Location** [app/controllers/accountcontroller.cs:36](#)**Function** app\_dll.Verademo.Controllers.AccountController.GetLogin

**Details** This call to `log4net_dll.log4net.ILog.Info()` could result in a log forging attack. Writing untrusted data into a log file allows an attacker to forge log entries or inject malicious content into log files. Corrupted log files can be used to cover an attacker's tracks or as a delivery mechanism for an attack on a log viewing or processing utility. For example, if a web administrator uses a browser-based utility to review logs, a cross-site scripting attack might be possible. The first argument to `Info()` contains tainted data from the variable `Concat()`. The tainted data originated from earlier calls to `app_dll.Verademo.Controllers.AccountController.GetLogin`, and `app_dll.VirtualController.vc_mvcentry`. Avoid directly embedding user input in log files when possible. Sanitize untrusted data used to construct log entries by using a safe logging mechanism such as the OWASP ESAPI Logger, which will automatically remove unexpected carriage returns and line feeds and can be configured to use HTML entity encoding for non-alphanumeric data. Alternatively, some of the XSS escaping functions from the OWASP Java Encoder project will also sanitize CRLF sequences. Only create a custom blocklist whe...

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/117.html>



**MEDIUM** CWE-117

#44

### Improper Output Neutralization for Logs

**Location** [app/controllers/accountcontroller.cs:86](#)**Function** `app_dll.Verademo.Controllers.AccountController.PostLogin`

**Details** This call to `log4net_dll.log4net.ILog.Info()` could result in a log forging attack. Writing untrusted data into a log file allows an attacker to forge log entries or inject malicious content into log files. Corrupted log files can be used to cover an attacker's tracks or as a delivery mechanism for an attack on a log viewing or processing utility. For example, if a web administrator uses a browser-based utility to review logs, a cross-site scripting attack might be possible. The first argument to `Info()` contains tainted data from the variable `Concat()`. The tainted data originated from earlier calls to `app_dll.Verademo.Controllers.AccountController.PostLogin`, and `app_dll.VirtualController.vc_mvcentry`. Avoid directly embedding user input in log files when possible. Sanitize untrusted data used to construct log entries by using a safe logging mechanism such as the OWASP ESAPI Logger, which will automatically remove unexpected carriage returns and line feeds and can be configured to use HTML entity encoding for non-alphanumeric data. Alternatively, some of the XSS escaping functions from the OWASP Java Encoder project will also sanitize CRLF sequences. Only create a custom blacklist wh...

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/117.html>**MEDIUM** CWE-117

#45

### Improper Output Neutralization for Logs

**Location** [app/controllers/accountcontroller.cs:232](#)**Function** `app_dll.Verademo.Controllers.AccountController.PostProfile`

**Details** This call to `log4net_dll.log4net.ILog.Info()` could result in a log forging attack. Writing untrusted data into a log file allows an attacker to forge log entries or inject malicious content into log files. Corrupted log files can be used to cover an attacker's tracks or as a delivery mechanism for an attack on a log viewing or processing utility. For example, if a web administrator uses a browser-based utility to review logs, a cross-site scripting attack might be possible. The first argument to `Info()` contains tainted data from the variable `Concat()`. The tainted data originated from earlier calls to `app_dll.Verademo.Controllers.AccountController.PostProfile`, and `app_dll.VirtualController.vc_mvcentry`. Avoid directly embedding user input in log files when possible. Sanitize untrusted data used to construct log entries by using a safe logging mechanism such as the OWASP ESAPI Logger, which will automatically remove unexpected carriage returns and line feeds and can be configured to use HTML entity encoding for non-alphanumeric data. Alternatively, some of the XSS escaping functions from the OWASP Java Encoder project will also sanitize CRLF sequences. Only create a custom blacklist...

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/117.html>**MEDIUM** CWE-117

#46

### Improper Output Neutralization for Logs

**Location** [app/controllers/accountcontroller.cs:260](#)**Function** `app_dll.Verademo.Controllers.AccountController.GetPasswordHint`

**Details** This call to `log4net_dll.log4net.ILog.Info()` could result in a log forging attack. Writing untrusted data into a log file allows an attacker to forge log entries or inject malicious content into log files. Corrupted log files can be used to cover an attacker's tracks or as a delivery mechanism for an attack on a log viewing or processing utility. For example, if a web administrator uses a browser-based utility to review logs, a cross-site scripting attack might be possible. The first argument to `Info()` contains tainted data from the variable `Concat()`. The tainted data originated from earlier calls to `app_dll.Verademo.Controllers.AccountController.GetPasswordHint`, and `app_dll.VirtualController.vc_mvcentry`. Avoid directly embedding user input in log files when possible. Sanitize untrusted data used to construct log entries by using a safe logging mechanism such as the OWASP ESAPI Logger, which will automatically remove unexpected carriage returns and line feeds and can be configured to use HTML entity encoding for non-alphanumeric data. Alternatively, some of the XSS escaping functions from the OWASP Java Encoder project will also sanitize CRLF sequences. Only create a custom blockl...

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/117.html>

**MEDIUM** CWE-117

#47

### Improper Output Neutralization for Logs

**Location** [app/controllers/accountcontroller.cs:360](#)**Function** app\_dll.Verademo.Controllers.AccountController.PopulateProfileViewModel

**Details** This call to `log4net_dll.log4net.ILog.Info()` could result in a log forging attack. Writing untrusted data into a log file allows an attacker to forge log entries or inject malicious content into log files. Corrupted log files can be used to cover an attacker's tracks or as a delivery mechanism for an attack on a log viewing or processing utility. For example, if a web administrator uses a browser-based utility to review logs, a cross-site scripting attack might be possible. The first argument to `Info()` contains tainted data. The tainted data originated from earlier calls to `app_dll.Verademo.Controllers.AccountController.PostProfile`, `app_dll.VirtualController.vc_mvcentry`, `microsoft_aspnetcore_http_abstractions_dll.Microsoft.AspNetCore.Http.HttpContext.get_Session`, and `app_dll.Verademo.Controllers.AccountController.PostRegister`. Avoid directly embedding user input in log files when possible. Sanitize untrusted data used to construct log entries by using a safe logging mechanism such as the OWASP ESAPI Logger, which will automatically remove unexpected carriage returns and line feeds and can be configured to use HTML entity encoding for non-alphanumeric data. Alternatively, some of t...

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/117.html>**MEDIUM** CWE-117

#48

### Improper Output Neutralization for Logs

**Location** [app/controllers/accountcontroller.cs:391](#)**Function** app\_dll.Verademo.Controllers.AccountController.DownloadProfileImage

**Details** This call to `log4net_dll.log4net.ILog.Info()` could result in a log forging attack. Writing untrusted data into a log file allows an attacker to forge log entries or inject malicious content into log files. Corrupted log files can be used to cover an attacker's tracks or as a delivery mechanism for an attack on a log viewing or processing utility. For example, if a web administrator uses a browser-based utility to review logs, a cross-site scripting attack might be possible. The first argument to `Info()` contains tainted data from the variable `Concat()`. The tainted data originated from earlier calls to `app_dll.VirtualController.vc_mvcentry`, and `app_dll.Verademo.Controllers.AccountController.DownloadProfileImage`. Avoid directly embedding user input in log files when possible. Sanitize untrusted data used to construct log entries by using a safe logging mechanism such as the OWASP ESAPI Logger, which will automatically remove unexpected carriage returns and line feeds and can be configured to use HTML entity encoding for non-alphanumeric data. Alternatively, some of the XSS escaping functions from the OWASP Java Encoder project will also sanitize CRLF sequences. Only create a custom b...

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/117.html>**MEDIUM** CWE-117

#49

### Improper Output Neutralization for Logs

**Location** [app/controllers/accountcontroller.cs:450](#)**Function** app\_dll.Verademo.Controllers.AccountController.RetrieveMyEvents

**Details** This call to `log4net_dll.log4net.ILog.Info()` could result in a log forging attack. Writing untrusted data into a log file allows an attacker to forge log entries or inject malicious content into log files. Corrupted log files can be used to cover an attacker's tracks or as a delivery mechanism for an attack on a log viewing or processing utility. For example, if a web administrator uses a browser-based utility to review logs, a cross-site scripting attack might be possible. The first argument to `Info()` contains tainted data. The tainted data originated from earlier calls to `app_dll.Verademo.Controllers.AccountController.PostProfile`, `app_dll.VirtualController.vc_mvcentry`, `microsoft_aspnetcore_http_abstractions_dll.Microsoft.AspNetCore.Http.HttpContext.get_Session`, and `app_dll.Verademo.Controllers.AccountController.PostRegister`. Avoid directly embedding user input in log files when possible. Sanitize untrusted data used to construct log entries by using a safe logging mechanism such as the OWASP ESAPI Logger, which will automatically remove unexpected carriage returns and line feeds and can be configured to use HTML entity encoding for non-alphanumeric data. Alternatively, some of t...

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/117.html>

**MEDIUM** CWE-915

#50

**Improperly Controlled Modification of Dynamically-Determined Object Attributes****Location** [app/controllers/accountcontroller.cs:79](#)**Function** `app_dll.Verademo.Controllers.AccountController.PostLogin`

**Details** .NET MVC uses a feature called Model Binding to automatically map HTTP POST Form parameters to a Model indicated by the type specified in the Controller Action's method argument. Since all HTTP POST data could be under the control of an attacker, additional values may be included beyond those intended. If those additional POST parameters match the names of attributes on the model, they may be updated as well. Explicitly specify which of the Model's attributes should be accessible using the Bind attribute by setting the Include property to each allowable property. If it is not feasible to use the preferred property Include, instead specify which attributes should not be accessible using the Bind attribute and setting the Exclude property to each prohibited property. Keep in mind that when choosing to exclude properties the issue will not be resolved due to possible future additions/changes of properties on the Model. References: CWE See Security Note on Implementing Basic CRUD Functionality with the Entity Framework in ASP.NET MVC Application

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/915.html>**MEDIUM** CWE-915

#51

**Improperly Controlled Modification of Dynamically-Determined Object Attributes****Location** [app/controllers/accountcontroller.cs:511](#)**Function** `app_dll.Verademo.Controllers.AccountController.PostRegisterFinish`

**Details** .NET MVC uses a feature called Model Binding to automatically map HTTP POST Form parameters to a Model indicated by the type specified in the Controller Action's method argument. Since all HTTP POST data could be under the control of an attacker, additional values may be included beyond those intended. If those additional POST parameters match the names of attributes on the model, they may be updated as well. Explicitly specify which of the Model's attributes should be accessible using the Bind attribute by setting the Include property to each allowable property. If it is not feasible to use the preferred property Include, instead specify which attributes should not be accessible using the Bind attribute and setting the Exclude property to each prohibited property. Keep in mind that when choosing to exclude properties the issue will not be resolved due to possible future additions/changes of properties on the Model. References: CWE See Security Note on Implementing Basic CRUD Functionality with the Entity Framework in ASP.NET MVC Application

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/915.html>**MEDIUM** CWE-601

#52

**URL Redirection to Untrusted Site ('Open Redirect')****Location** [app/controllers/accountcontroller.cs:73](#)**Function** `app_dll.Verademo.Controllers.AccountController.GetLogin`

**Details** This call to `microsoft_aspnetcore_mvc_core_dll.Microsoft.AspNetCore.Mvc.ControllerBase.Redirect()` contains a URL redirection to untrusted site flaw. Writing untrusted input into a URL value could cause the web application to redirect the request to the specified URL, leading to phishing attempts to steal user credentials. Always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible. The first argument to `Redirect()` contains tainted data from the variable `ReturnUrl`. The tainted data originated from earlier calls to `app_dll.VirtualController.vc_mvcentry`, and `app_dll.Verademo.Controllers.AccountController.GetLogin`.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/601.html>

**MEDIUM** CWE-601

#53

**URL Redirection to Untrusted Site ('Open Redirect')****Location** [app/controllers/accountcontroller.cs:116](#)**Function** `app_dll.Verademo.Controllers.AccountController.PostLogin`

**Details** This call to `microsoft_aspnetcore_mvc_core_dll.Microsoft.AspNetCore.Mvc.ControllerBase.Redirect()` contains a URL redirection to untrusted site flaw. Writing untrusted input into a URL value could cause the web application to redirect the request to the specified URL, leading to phishing attempts to steal user credentials. Always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible. The first argument to `Redirect()` contains tainted data from the variable `ReturnUrl`. The tainted data originated from earlier calls to `app_dll.VirtualController.vc_mvcentry`, and `app_dll.Verademo.Controllers.AccountController.PostLogin`.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/601.html>**MEDIUM** CWE-327

#54

**Use of a Broken or Risky Cryptographic Algorithm****Location** [app/controllers/authcontrollerbase.cs:78](#)**Function** `app_dll.Verademo.Controllers.AuthControllerBase.Md5Hash`

**Details** This function uses the `system_security_cryptography_dll.System.Security.Cryptography.MD5.Create()` function, which uses a hash algorithm that is considered weak. In recent years, researchers have demonstrated ways to breach many uses of previously-thought-safe hash functions such as MD5. Consider using a stronger algorithm in order to prevent attackers from being able to manipulate hash results. If this algorithm is being used to hash passwords, then consider using a strong computationally-hard algorithm such as PBKDF2 or bcrypt instead of a plain hashing algorithm.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/327.html>**MEDIUM** CWE-470

#55

**Use of Externally-Controlled Input to Select Classes or Code ('Unsafe Reflection')****Location** [app/controllers/blabcontroller.cs:307](#)**Function** `app_dll.Verademo.Controllers.BlabController.PostBlabbers`

**Details** This call to `system_runtime_dll.System.Activator.CreateInstance()` uses reflection in an unsafe manner. An attacker can specify the class name to be instantiated, which may create unexpected control flow paths through the application. Depending on how reflection is being used, the attack vector may allow the attacker to bypass security checks or otherwise cause the application to behave in an unexpected manner. Even if the object does not implement the specified interface and a `ClassCastException` is thrown, the constructor of the untrusted class name will have already executed. The first argument to `CreateInstance()` contains tainted data. The tainted data originated from earlier calls to `app_dll.VirtualController.vc_mvcentry`, and `app_dll.Verademo.Controllers.BlabController.PostBlabbers`. Validate the class name against a combination of white and blocklists to ensure that only expected behavior is produced.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/470.html>

**MEDIUM** CWE-117

#56

**Improper Output Neutralization for Logs****Location** [app/controllers/resetcontroller.cs:152](#)**Function** app\_dll.Verademo.Controllers.ResetController.AddListener

**Details** This call to `log4net_dll.log4net.ILog.Info()` could result in a log forging attack. Writing untrusted data into a log file allows an attacker to forge log entries or inject malicious content into log files. Corrupted log files can be used to cover an attacker's tracks or as a delivery mechanism for an attack on a log viewing or processing utility. For example, if a web administrator uses a browser-based utility to review logs, a cross-site scripting attack might be possible. The first argument to `Info()` contains tainted data from the variable `Concat()`. The tainted data originated from an earlier call to `app_dll.VirtualController.vc_mvcentry`. Avoid directly embedding user input in log files when possible. Sanitize untrusted data used to construct log entries by using a safe logging mechanism such as the OWASP ESAPI Logger, which will automatically remove unexpected carriage returns and line feeds and can be configured to use HTML entity encoding for non-alphanumeric data. Alternatively, some of the XSS escaping functions from the OWASP Java Encoder project will also sanitize CRLF sequences. Only create a custom blocklist when absolutely necessary. Always validate untrusted input to...

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/117.html>**MEDIUM** CWE-117

#57

**Improper Output Neutralization for Logs****Location** [app/controllers/resetcontroller.cs:173](#)**Function** app\_dll.Verademo.Controllers.ResetController.AddUserData

**Details** This call to `log4net_dll.log4net.ILog.Info()` could result in a log forging attack. Writing untrusted data into a log file allows an attacker to forge log entries or inject malicious content into log files. Corrupted log files can be used to cover an attacker's tracks or as a delivery mechanism for an attack on a log viewing or processing utility. For example, if a web administrator uses a browser-based utility to review logs, a cross-site scripting attack might be possible. The first argument to `Info()` contains tainted data from the variable `Concat()`. The tainted data originated from an earlier call to `app_dll.VirtualController.vc_mvcentry`. Avoid directly embedding user input in log files when possible. Sanitize untrusted data used to construct log entries by using a safe logging mechanism such as the OWASP ESAPI Logger, which will automatically remove unexpected carriage returns and line feeds and can be configured to use HTML entity encoding for non-alphanumeric data. Alternatively, some of the XSS escaping functions from the OWASP Java Encoder project will also sanitize CRLF sequences. Only create a custom blocklist when absolutely necessary. Always validate untrusted input to...

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/117.html>**MEDIUM** CWE-117

#58

**Improper Output Neutralization for Logs****Location** [app/controllers/resetcontroller.cs:207](#)**Function** app\_dll.Verademo.Controllers.ResetController.AddBlabs

**Details** This call to `log4net_dll.log4net.ILog.Info()` could result in a log forging attack. Writing untrusted data into a log file allows an attacker to forge log entries or inject malicious content into log files. Corrupted log files can be used to cover an attacker's tracks or as a delivery mechanism for an attack on a log viewing or processing utility. For example, if a web administrator uses a browser-based utility to review logs, a cross-site scripting attack might be possible. The first argument to `Info()` contains tainted data from the variable `Concat()`. The tainted data originated from an earlier call to `app_dll.VirtualController.vc_mvcentry`. Avoid directly embedding user input in log files when possible. Sanitize untrusted data used to construct log entries by using a safe logging mechanism such as the OWASP ESAPI Logger, which will automatically remove unexpected carriage returns and line feeds and can be configured to use HTML entity encoding for non-alphanumeric data. Alternatively, some of the XSS escaping functions from the OWASP Java Encoder project will also sanitize CRLF sequences. Only create a custom blocklist when absolutely necessary. Always validate untrusted input to...

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/117.html>

**MEDIUM** CWE-117

#59

**Improper Output Neutralization for Logs****Location** [app/controllers/resetcontroller.cs:259](#)**Function** app\_dll.Verademo.Controllers.ResetController.AddComments

**Details** This call to `log4net.dll.log4net.ILog.Info()` could result in a log forging attack. Writing untrusted data into a log file allows an attacker to forge log entries or inject malicious content into log files. Corrupted log files can be used to cover an attacker's tracks or as a delivery mechanism for an attack on a log viewing or processing utility. For example, if a web administrator uses a browser-based utility to review logs, a cross-site scripting attack might be possible. The first argument to `Info()` contains tainted data from the variable `Concat()`. The tainted data originated from an earlier call to `app_dll.VirtualController.vc_mvcentry`. Avoid directly embedding user input in log files when possible. Sanitize untrusted data used to construct log entries by using a safe logging mechanism such as the OWASP ESAPI Logger, which will automatically remove unexpected carriage returns and line feeds and can be configured to use HTML entity encoding for non-alphanumeric data. Alternatively, some of the XSS escaping functions from the OWASP Java Encoder project will also sanitize CRLF sequences. Only create a custom blocklist when absolutely necessary. Always validate untrusted input to...

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/117.html>**MEDIUM** CWE-331

#60

**Insufficient Entropy****Location** [app/controllers/resetcontroller.cs:147](#)**Function** app\_dll.Verademo.Controllers.ResetController.AddListeners

**Details** Standard random number generators do not provide a sufficient amount of entropy when used for security purposes. Attackers can brute force the output of pseudorandom number generators such as `rand()`. If this random number is used where security is a concern, such as generating a session key or session identifier, use a trusted cryptographic random number generator instead. These can be found on the Windows platform in the CryptoAPI or in an open source library such as OpenSSL. In Java, use the `SecureRandom` object to ensure sufficient entropy.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/331.html>**MEDIUM** CWE-331

#61

**Insufficient Entropy****Location** [app/controllers/resetcontroller.cs:201](#)**Function** app\_dll.Verademo.Controllers.ResetController.AddBlabs

**Details** Standard random number generators do not provide a sufficient amount of entropy when used for security purposes. Attackers can brute force the output of pseudorandom number generators such as `rand()`. If this random number is used where security is a concern, such as generating a session key or session identifier, use a trusted cryptographic random number generator instead. These can be found on the Windows platform in the CryptoAPI or in an open source library such as OpenSSL. In Java, use the `SecureRandom` object to ensure sufficient entropy.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/331.html>



**MEDIUM** CWE-331

#62

### Insufficient Entropy

**Location** [app/controllers/resetcontroller.cs:204](#)**Function** `app_dll.Verademo.Controllers.ResetController.AddBlabs`

**Details** Standard random number generators do not provide a sufficient amount of entropy when used for security purposes. Attackers can brute force the output of pseudorandom number generators such as `rand()`. If this random number is used where security is a concern, such as generating a session key or session identifier, use a trusted cryptographic random number generator instead. These can be found on the Windows platform in the CryptoAPI or in an open source library such as OpenSSL. In Java, use the `SecureRandom` object to ensure sufficient entropy.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/331.html>**MEDIUM** CWE-331

#63

### Insufficient Entropy

**Location** [app/controllers/resetcontroller.cs:239](#)**Function** `app_dll.Verademo.Controllers.ResetController.AddComments`

**Details** Standard random number generators do not provide a sufficient amount of entropy when used for security purposes. Attackers can brute force the output of pseudorandom number generators such as `rand()`. If this random number is used where security is a concern, such as generating a session key or session identifier, use a trusted cryptographic random number generator instead. These can be found on the Windows platform in the CryptoAPI or in an open source library such as OpenSSL. In Java, use the `SecureRandom` object to ensure sufficient entropy.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/331.html>**MEDIUM** CWE-331

#64

### Insufficient Entropy

**Location** [app/controllers/resetcontroller.cs:249](#)**Function** `app_dll.Verademo.Controllers.ResetController.AddComments`

**Details** Standard random number generators do not provide a sufficient amount of entropy when used for security purposes. Attackers can brute force the output of pseudorandom number generators such as `rand()`. If this random number is used where security is a concern, such as generating a session key or session identifier, use a trusted cryptographic random number generator instead. These can be found on the Windows platform in the CryptoAPI or in an open source library such as OpenSSL. In Java, use the `SecureRandom` object to ensure sufficient entropy.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/331.html>**MEDIUM** CWE-331

#65

### Insufficient Entropy

**Location** [app/controllers/resetcontroller.cs:253](#)**Function** `app_dll.Verademo.Controllers.ResetController.AddComments`

**Details** Standard random number generators do not provide a sufficient amount of entropy when used for security purposes. Attackers can brute force the output of pseudorandom number generators such as `rand()`. If this random number is used where security is a concern, such as generating a session key or session identifier, use a trusted cryptographic random number generator instead. These can be found on the Windows platform in the CryptoAPI or in an open source library such as OpenSSL. In Java, use the `SecureRandom` object to ensure sufficient entropy.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/331.html>

**MEDIUM** CWE-331

#66

**Insufficient Entropy****Location** [app/controllers/resetcontroller.cs:257](#)**Function** `app_dll.Verademo.Controllers.ResetController.AddComments`

**Details** Standard random number generators do not provide a sufficient amount of entropy when used for security purposes. Attackers can brute force the output of pseudorandom number generators such as `rand()`. If this random number is used where security is a concern, such as generating a session key or session identifier, use a trusted cryptographic random number generator instead. These can be found on the Windows platform in the CryptoAPI or in an open source library such as OpenSSL. In Java, use the `SecureRandom` object to ensure sufficient entropy.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/331.html>**MEDIUM** CWE-117

#67

**Improper Output Neutralization for Logs****Location** [app/controllers/toolscontroller.cs:53](#)**Function** `app_dll.Verademo.Controllers.ToolsController.Ping`

**Details** This call to `log4net_dll.log4net.ILog.Info()` could result in a log forging attack. Writing untrusted data into a log file allows an attacker to forge log entries or inject malicious content into log files. Corrupted log files can be used to cover an attacker's tracks or as a delivery mechanism for an attack on a log viewing or processing utility. For example, if a web administrator uses a browser-based utility to review logs, a cross-site scripting attack might be possible. The first argument to `Info()` contains tainted data from the variable `Concat()`. The tainted data originated from earlier calls to `app_dll.VirtualController.vc_mvcentry`, and `app_dll.Verademo.Controllers.ToolsController.Tools`. Avoid directly embedding user input in log files when possible. Sanitize untrusted data used to construct log entries by using a safe logging mechanism such as the OWASP ESAPI Logger, which will automatically remove unexpected carriage returns and line feeds and can be configured to use HTML entity encoding for non-alphanumeric data. Alternatively, some of the XSS escaping functions from the OWASP Java Encoder project will also sanitize CRLF sequences. Only create a custom blacklist when abs...

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/117.html>**MEDIUM** CWE-798

#68

**Use of Hard-coded Credentials****Location** [app/data/applicationdbcontext.cs:9](#)**Function** `app_dll.Verademo.Data.ApplicationDbContext.ctor`

**Details** The application contains hard-coded information that may contain credentials to an external service. The use of hard-coded credentials significantly increases the possibility that the account being protected will be compromised. constructor Store credentials out-of-band from the application code. Follow best practices for protecting credentials stored in locations such as configuration or properties files.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/798.html>**MEDIUM** CWE-327

#69

**Use of a Broken or Risky Cryptographic Algorithm****Location** [app/models/user.cs:51](#)**Function** `app_dll.Verademo.Models.User.Md5Hash`

**Details** This function uses the `!cil_arrayimp()` function, which uses a hash algorithm that is considered weak. In recent years, researchers have demonstrated ways to breach many uses of previously-thought-safe hash functions such as MD5. Consider using a stronger algorithm in order to prevent attackers from being able to manipulate hash results. If this algorithm is being used to hash passwords, then consider using a strong computationally-hard algorithm such as PBKDF2 or `bcrypt` instead of a plain hashing algorithm.

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/327.html>

**LOW** CWE-1174

#70

**ASP.NET Misconfiguration: Improper Model Validation****Location** `app/controllers/accountcontroller.cs:511`**Function** `app_dll.Verademo.Controllers.AccountController.PostRegisterFinish`

**Details** The Controller's Action has a model that fails to perform Model Validation. This could expose the application to other weaknesses related to insufficient input validation. Be sure to check the ModelState.IsValid property in the Controller Action before using the data contained within the model. Note: This flaw used to be reported as CWE 100, which has been deprecated by MITRE. References: CWE Models and Validation in ASP.NET Core MVC Models and Validation in ASP.NET MVC

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/1174.html>**LOW** CWE-1174

#71

**ASP.NET Misconfiguration: Improper Model Validation****Location** `app/models/loginviewmodel.cs:11`**Function** `app_dll.Verademo.Models.LoginView.get_Password`

**Details** The Controller's Action has a model that fails to perform Model Validation due to a lack of Data Annotations on the Model. This could expose the application to other weaknesses related to insufficient input validation. Be sure to add Data Annotation attributes on each property of the Model. For example, to validate a credit card number use the CreditCardAttribute. For validation that is more flexible use RegularExpressionAttribute or CustomValidationAttribute. These data annotations can be found in the System.ComponentModel.DataAnnotations namespace. Note: This flaw used to be reported as CWE 100, which has been deprecated by MITRE. References: CWE Models and Validation in ASP.NET Core MVC How to: Validate Model Data Using DataAnnotations Attributes Model Validation in ASP.NET Web API

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/1174.html>**LOW** CWE-1174

#72

**ASP.NET Misconfiguration: Improper Model Validation****Location** `app/models/loginviewmodel.cs:12`**Function** `app_dll.Verademo.Models.LoginView.get_ReturnURL`

**Details** The Controller's Action has a model that fails to perform Model Validation due to a lack of Data Annotations on the Model. This could expose the application to other weaknesses related to insufficient input validation. Be sure to add Data Annotation attributes on each property of the Model. For example, to validate a credit card number use the CreditCardAttribute. For validation that is more flexible use RegularExpressionAttribute or CustomValidationAttribute. These data annotations can be found in the System.ComponentModel.DataAnnotations namespace. Note: This flaw used to be reported as CWE 100, which has been deprecated by MITRE. References: CWE Models and Validation in ASP.NET Core MVC How to: Validate Model Data Using DataAnnotations Attributes Model Validation in ASP.NET Web API

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/1174.html>

**LOW** CWE-1174

#73

**ASP.NET Misconfiguration: Improper Model Validation****Location** [app/models/user.cs:10](#)**Function** `app_dll.Verademo.Models.User.get_UserName`

**Details** The Controller's Action has a model that fails to perform Model Validation due to a lack of Data Annotations on the Model. This could expose the application to other weaknesses related to insufficient input validation. Be sure to add Data Annotation attributes on each property of the Model. For example, to validate a credit card number use the `CreditCardAttribute`. For validation that is more flexible use `RegularExpressionAttribute` or `CustomValidationAttribute`. These data annotations can be found in the `System.ComponentModel.DataAnnotations` namespace. Note: This flaw used to be reported as CWE 100, which has been deprecated by MITRE. References: [CWE Models and Validation in ASP.NET Core MVC How to: Validate Model Data Using DataAnnotations Attributes](#) [Model Validation in ASP.NET Web API](#)

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/1174.html>**LOW** CWE-1174

#74

**ASP.NET Misconfiguration: Improper Model Validation****Location** [app/models/user.cs:11](#)**Function** `app_dll.Verademo.Models.User.get_BlabName`

**Details** The Controller's Action has a model that fails to perform Model Validation due to a lack of Data Annotations on the Model. This could expose the application to other weaknesses related to insufficient input validation. Be sure to add Data Annotation attributes on each property of the Model. For example, to validate a credit card number use the `CreditCardAttribute`. For validation that is more flexible use `RegularExpressionAttribute` or `CustomValidationAttribute`. These data annotations can be found in the `System.ComponentModel.DataAnnotations` namespace. Note: This flaw used to be reported as CWE 100, which has been deprecated by MITRE. References: [CWE Models and Validation in ASP.NET Core MVC How to: Validate Model Data Using DataAnnotations Attributes](#) [Model Validation in ASP.NET Web API](#)

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/1174.html>**LOW** CWE-1174

#75

**ASP.NET Misconfiguration: Improper Model Validation****Location** [app/models/user.cs:12](#)**Function** `app_dll.Verademo.Models.User.get_RealName`

**Details** The Controller's Action has a model that fails to perform Model Validation due to a lack of Data Annotations on the Model. This could expose the application to other weaknesses related to insufficient input validation. Be sure to add Data Annotation attributes on each property of the Model. For example, to validate a credit card number use the `CreditCardAttribute`. For validation that is more flexible use `RegularExpressionAttribute` or `CustomValidationAttribute`. These data annotations can be found in the `System.ComponentModel.DataAnnotations` namespace. Note: This flaw used to be reported as CWE 100, which has been deprecated by MITRE. References: [CWE Models and Validation in ASP.NET Core MVC How to: Validate Model Data Using DataAnnotations Attributes](#) [Model Validation in ASP.NET Web API](#)

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/1174.html>

**LOW** CWE-1174

#76

**ASP.NET Misconfiguration: Improper Model Validation****Location** [app/models/user.cs:13](#)**Function** `app_dll.Verademo.Models.User.get_Password`

**Details** The Controller's Action has a model that fails to perform Model Validation due to a lack of Data Annotations on the Model. This could expose the application to other weaknesses related to insufficient input validation. Be sure to add Data Annotation attributes on each property of the Model. For example, to validate a credit card number use the `CreditCardAttribute`. For validation that is more flexible use `RegularExpressionAttribute` or `CustomValidationAttribute`. These data annotations can be found in the `System.ComponentModel.DataAnnotations` namespace. Note: This flaw used to be reported as CWE 100, which has been deprecated by MITRE. References: [CWE Models and Validation in ASP.NET Core MVC How to: Validate Model Data Using DataAnnotations Attributes](#) [Model Validation in ASP.NET Web API](#)

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/1174.html>**LOW** CWE-1174

#77

**ASP.NET Misconfiguration: Improper Model Validation****Location** [app/models/user.cs:14](#)**Function** `app_dll.Verademo.Models.User.get_PasswordHint`

**Details** The Controller's Action has a model that fails to perform Model Validation due to a lack of Data Annotations on the Model. This could expose the application to other weaknesses related to insufficient input validation. Be sure to add Data Annotation attributes on each property of the Model. For example, to validate a credit card number use the `CreditCardAttribute`. For validation that is more flexible use `RegularExpressionAttribute` or `CustomValidationAttribute`. These data annotations can be found in the `System.ComponentModel.DataAnnotations` namespace. Note: This flaw used to be reported as CWE 100, which has been deprecated by MITRE. References: [CWE Models and Validation in ASP.NET Core MVC How to: Validate Model Data Using DataAnnotations Attributes](#) [Model Validation in ASP.NET Web API](#)

**Reference** <https://downloads.veracode.com/securityscan/cwe/v5/net/1174.html>

## Software Composition Analysis (SCA)

REVIEW

7 finding(s) - 7 at or above threshold 'medium'

[Full results on the Veracode platform](#)

### Vulnerable dependencies (7)

|                                                                                                                                                                                                                                                                    |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <div><div>CRITICAL 9.8</div><div>CVE-2021-24112</div></div> <div>#1</div> <div>Remote Code Execution (RCE)</div> <div><div>Package</div><div>System.Drawing.Common 4.7.0</div></div>                                                                               |
| <div><div>HIGH 7.5</div><div>CVE-2024-43483</div></div> <div>#2</div> <div>Denial Of Service (DoS)</div> <div><div>Package</div><div>Microsoft.Extensions.Caching.Memory 8.0.0</div></div>                                                                         |
| <div><div>HIGH 8.7</div><div>CVE-2024-0056</div></div> <div>#3</div> <div>Credential Exposure</div> <div><div>Package</div><div>System.Data.SqlClient 4.8.1</div></div>                                                                                            |
| <div><div>HIGH 7.5</div><div>CVE-2024-30105</div></div> <div>#4</div> <div>Denial Of Service (DoS)</div> <div><div>Package</div><div>System.Text.Json 8.0.0</div></div>                                                                                            |
| <div><div>HIGH 7.5</div><div>CVE-2024-43485</div></div> <div>#5</div> <div>Denial Of Service (DoS)</div> <div><div>Package</div><div>System.Text.Json 8.0.0</div></div>                                                                                            |
| <div><div>MEDIUM 5.8</div><div>CVE-2022-41064</div></div> <div>#6</div> <div>Information Disclosure</div> <div><div>Package</div><div>System.Data.SqlClient 4.8.1</div></div>                                                                                      |
| <div><div>MEDIUM 5.3</div><div>CVE-2026-40021</div></div> <div>#7</div> <div>Apache Log4net: Silent log event loss in XmlLayout and XmlLayoutSchemaLog4J due to unescaped XML 1.0 forbidden character</div> <div><div>Package</div><div>log4net 2.0.17</div></div> |

## Infrastructure as Code & Secrets

**REVIEW** 4 finding(s) - 3 at or above threshold 'high'

### Infrastructure misconfigurations (4)

**CRITICAL** DS031

#1

#### Secrets passed via `build-args` or envs or copied secret files

|             |                                                                                                                                  |
|-------------|----------------------------------------------------------------------------------------------------------------------------------|
| Location    | Dockerfile:16                                                                                                                    |
| Source      | 16: ENV SA_PASSWORD=[REDACTED]                                                                                                   |
| Remediation | Use secret mount if secrets are needed during image build. Use volume mount if secret files are needed during container runtime. |
| Scope       | general                                                                                                                          |
| Details     | Passing secrets via `build-args` or envs or copying secret files can leak them out                                               |
| Reference   | <a href="https://docs.docker.com/build/building/secrets/">https://docs.docker.com/build/building/secrets/</a>                    |

**HIGH** DS029

#2

#### 'apt-get' missing '--no-install-recommends'

|             |                                                                                                                                                                   |
|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Location    | Dockerfile:23                                                                                                                                                     |
| Source      | 23: RUN apt-get update \                                                                                                                                          |
| Remediation | Add '--no-install-recommends' flag to 'apt-get'                                                                                                                   |
| Scope       | general                                                                                                                                                           |
| Details     | 'apt-get' install should use '--no-install-recommends' to minimize image size.                                                                                    |
| Reference   | <a href="https://docs.docker.com/develop/develop-images/dockerfile_best-practices/">https://docs.docker.com/develop/develop-images/dockerfile_best-practices/</a> |

**HIGH** DS002

#3

#### Image user should not be 'root'

|             |                                                                                                                                                                                                            |
|-------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Location    | Dockerfile:11                                                                                                                                                                                              |
| Source      | 11: USER root                                                                                                                                                                                              |
| Remediation | Add 'USER <non root user name>' line to the Dockerfile                                                                                                                                                     |
| Scope       | general                                                                                                                                                                                                    |
| Details     | Running containers with 'root' user can lead to a container escape situation. It is a best practice to run containers as non-root users, which can be done by adding a 'USER' statement to the Dockerfile. |
| Reference   | <a href="https://docs.docker.com/develop/develop-images/dockerfile_best-practices/">https://docs.docker.com/develop/develop-images/dockerfile_best-practices/</a>                                          |

**LOW** DS026

#4

#### No HEALTHCHECK defined

|             |                                                                                                                           |
|-------------|---------------------------------------------------------------------------------------------------------------------------|
| Location    | Dockerfile                                                                                                                |
| Remediation | Add HEALTHCHECK instruction in Dockerfile                                                                                 |
| Scope       | general                                                                                                                   |
| Details     | You should add HEALTHCHECK instruction in your docker container images to perform the health check on running containers. |



## Appendix

### Severity model

Every finding is ranked on the higher of its reported severity label and the band derived from its CVSS base score, so a finding labelled Unknown that carries a high score is not under-rated. A finding with no usable severity signal is floored rather than treated as informational: exposed secrets floor to High, everything else to Medium.

| Band     | CVSS base score | Interpretation                                        |
|----------|-----------------|-------------------------------------------------------|
| Critical | 9.0 - 10.0      | Exploitable with severe impact. Fix before merging.   |
| High     | 7.0 - 8.9       | Significant risk. Fix in this change where practical. |
| Medium   | 4.0 - 6.9       | Moderate risk. Schedule remediation.                  |
| Low      | 0.1 - 3.9       | Limited risk. Address opportunistically.              |
| Info     | 0.0 or none     | No direct risk. Provided for awareness.               |

### Thresholds applied

A finding at or above its scan's threshold is counted as needing review on the summary page. Thresholds are set per scan when the report runs and default to medium. They order the work in this report and do not gate a build.

| Scan                                | Threshold | Findings at or above it |
|-------------------------------------|-----------|-------------------------|
| Static Analysis (SAST)              | medium    | 69                      |
| Software Composition Analysis (SCA) | medium    | 7                       |
| Infrastructure as Code & Secrets    | high      | 3                       |

### About this report

Produced by the Veracode GitHub workflow integration from the results of the pipeline SAST scan, the agent-based SCA scan and the IaC/Secrets scan for this commit. Identifiers and file locations link back to the source in GitHub and to the relevant CWE, CVE or advisory record. Findings are point-in-time and reflect only what these three scans observed; they are not a statement that no other issue exists.